

# SRV Release QA Audit Fix Report

Prepared from workbook: SRV\_Release\_QA\_Audit\_2026-05-29 (1).xlsx

Audit date: 2026-05-29 | Report date: 2026-05-29 | Scope reviewed: ADMIN-BACKEND, ADMIN-FRONTEND, NEW APP

## Summary

- ? The uploaded workbook is primarily a static security and permission audit. The most actionable release-blocking issues were concentrated in the backend API layer rather than UI rendering.
- ? This pass focused on implementing the highest-risk fixes that were clearly reproducible from code review: CORS hardening, mobile authentication fixes, OTP verification gating for signup, admin role enforcement on sensitive routes, gift stock protection, and KYC upload MIME handling.
- ? Backend verification completed successfully: TypeScript no-emit check passed and production build passed after running outside the sandbox for dist output writing.

## Bug-by-Bug Mapping

| Bug ID      | Summary                                          | Status | Fix / Mapping                                                                                                                                                                                  |
|-------------|--------------------------------------------------|--------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SRV-BUG-001 | Permissive CORS allows every origin              | Fixed  | Hardened CORS allow-list in C:/Users/dell/Desktop/ADMIN-BACKEND/src/main.ts:26-33. Unknown browser origins now fail instead of being auto-allowed.                                             |
| SRV-BUG-002 | Mobile empty password login issues tokens        | Fixed  | Blocked empty-password token issuance in C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/mobile-auth/mobile-auth.service.ts:448 and updated no-password fallback at line 458.                  |
| SRV-BUG-003 | OTP values are logged                            | Fixed  | Removed login/signup OTP console logging from C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/mobile-auth/mobile-auth.service.ts around sendOtp/sendSignupOtp.                                 |
| SRV-BUG-004 | Signup endpoints do not enforce verified OTP     | Fixed  | Added VERIFIED OTP marker, signup OTP key helper, and registration gate in C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/mobile-auth/mobile-auth.service.ts:23, 160-178, 272, 308, 367, 402. |
| SRV-BUG-005 | Admin wallet credit/debit lack role guard        | Fixed  | Added RolesGuard + @Roles to wallet controller in C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/wallet/wallet.controller.ts:22, 51, 59. Staff remains read-only for transaction views.       |
| SRV-BUG-006 | Redemption approve/reject/delete lack role guard | Fixed  | Added RolesGuard + @Roles in C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/redemption/redemption.controller.ts:21, 49, 62, 70, 82 so only admin/super_admin can mutate.                      |
| SRV-BUG-007 | Several admin controllers rely only on JWT       | Fixed  | Added RolesGuard + route-level roles in analytics, offers, support, scans, and referrals controllers under C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/*.                                  |

## Additional Fixes Applied

- ? Mobile reward redemption now blocks out-of-stock gift schemes before debiting points in C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/mobile/mobile.service.ts:1111 and always decrements stock only after the validated flow at line 1206.
- ? KYC upload endpoint now correctly accepts PDF MIME type using application/pdf in C:/Users/dell/Desktop/ADMIN-BACKEND/src/modules/upload/upload.controller.ts:215-218.

## Pending / Not Fully Fixed In This Pass

| Area                                | Status  | Reason / Recommendation                                                                                                                                                                                                                |
|-------------------------------------|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| PII / KYC file exposure             | Pending | Uploaded KYC files are still publicly reachable via /uploads. Fixing this safely needs an authenticated file-delivery design or signed URL flow, plus frontend updates because current admin/mobile screens consume direct image URLs. |
| Gift-order rejection refund linkage | Pending | Gift rejection currently restores stock, but a fully reliable points refund path needs explicit linkage between GiftOrder and Redemption/Wallet entries. The current schema does not store a direct redemptionId on gift_orders.       |

| Area                    | Status  | Reason / Recommendation                                                                                                                                                                                                |
|-------------------------|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Performance audit items | Pending | 50MB body limit and runtime DDL concerns were not changed in this pass because they need broader infra and migration review before safe rollout.                                                                       |
| Runtime E2E validation  | Pending | The source workbook itself noted backend localhost:3001 and Expo localhost:8081 were unavailable during audit. This pass verified static/backend compile quality, but not a full live browser/device regression suite. |

## Verification Completed

- ? ADMIN-BACKEND: npx tsc --noEmit --pretty false --incremental false ? Passed
- ? ADMIN-BACKEND: npm run build ? Passed
- ? ADMIN-FRONTEND was not reworked in this pass beyond prior KYC/UI changes already completed earlier in the session.